

A Risk-Based Policy Framework for Mitigating Insider Compromise at Mongrov Inc

Student ID: 5653630, May 2026

Information Risk and Security Management (WM279), WMG, University of Warwick

Contents

1	Introduction	1
1.1	Case Context, Scope and Assumptions	1
2	Review of IT and Policy Failures	1
2.1	Identity and Hiring Verification Failures	1
2.2	Access Control and Privilege Management Failures	1
2.3	Monitoring and Insider Threat Detection Failures	2
3	Policy Analysis	2
3.1	Identity Verification and Trusted Onboarding Policy	2
3.2	Role-Based Access Control and Least Privilege Policy	3
3.3	Continuous Monitoring and Insider Detection Policy	3
3.4	Incident Response and Account Containment Policy	4
3.5	Practical Limitations of Policy Enforcement	4
4	Recommendations	5
4.1	Risk-Based Policy Prioritisation	5
5	Conclusion	5
	References	6
	Appendices	10
A	AI Declaration and Academic Integrity	10

1 Introduction

1.1 Case Context, Scope and Assumptions

The emergence of fraudulent remote IT workers operating under false or stolen identities has created a well-documented insider compromise risk in modern organisations, where insiders utilise stolen identities to infiltrate critical systems, a form of insider compromise which has become common [1]. The use of such a threat has mainly involved issues of extortion, sanction avoidance, stealing of information, and privilege abuse, among other things, illustrating what can happen due to poor governance of trust within an organisation. In response, Mongrov Inc requires a structured review of the control failures and policy shortcomings that permitted this abuse of internal trust. This report therefore not only analyses the policy shortcomings that facilitated this insider abuse of trust, but also proposes policy implementation recommendations to mitigate future related attacks. In the absence of full visibility into Mongrov Inc's internal controls, this review adopts reasonable assumptions based on ISO 27001, NIST, and broader insider threat literature.

2 Review of IT and Policy Failures

A critical examination of Mongrov Inc exposes several interrelated IT, organisational control, and assurance failures that enabled an organisational security breakdown rather than an isolated technical intrusion. In particular, deficiencies in remote identity verification, excessive privilege allocation, and behavioural oversight created a sequential control breakdown that amplified one organisational weakness directly to the next.

2.1 Identity and Hiring Verification Failures

The first major organisational weakness was Mongrov Inc's insufficient remote identity verification during recruitment and onboarding, which enabled false or stolen credentials to bypass standard onboarding scrutiny. Rather than applying enhanced vetting to personnel expected to handle sensitive systems (live verification, biometric confirmation, etc.), the organisation appears to have relied largely on standard recruitment checks typically used for general employees [2]. This indicates that successful HR onboarding was incorrectly treated as sufficient cyber security assurance, despite the elevated trust risks attached to remote technical hires. As a result, attackers were able to establish a false baseline of organisational trust from which subsequent access permissions were granted with minimal suspicion. Therefore, Mongrov Inc's failure lay not solely in admitting fraudulent workers, but in failing to contain the damage potential once they had been admitted through excessive internal privilege allocation.

2.2 Access Control and Privilege Management Failures

In addition to the above-stated shortcomings during the onboarding process, Mongrov Inc exhibited a deficiency in access control measures, which allowed the fraudsters to leverage their employment legitimacy to gain broad internal operational access [3]. This absence of graduated access restriction substantially amplified the insider threat once the fraudulent employees were successfully admitted into the organisation. Internal user accounts were seemingly provisioned with permissions on the basis of employment legitimacy instead of real operational needs, with Mongrov Inc appearing to have provided excessive operational

access without proper segregation of duties and privileges. This widened the insider threat by giving malicious users greater opportunities for misuse and lateral movement. Therefore, Mongrov Inc's failure lay not solely in admitting fraudulent workers, but in granting them disproportionate internal privilege after admission.

2.3 Monitoring and Insider Threat Detection Failures

Apart from the recruitment and access management issues outlined above, Mongrov Inc was also deficient in its ability to continuously monitor and manage user behaviour in order to detect any suspicious activity taking place under the guise of authorised user accounts [4]. This suggests the organisation relied more on static authentication, rather than adopting more mature forms of continuous authentication processes that could detect suspicious behaviours among authorised employee accounts. Ultimately, the incident highlights how several organisational control failures worked together to prolong attacker access and increase overall organisational exposure.

3 Policy Analysis

Addressing the failures identified in Section 2 requires a structured framework, which is based around reducing fraudulent entry, limiting privilege abuse, and strengthening post-compromise resilience.

3.1 Identity Verification and Trusted Onboarding Policy

The first and most preventative control required at Mongrov Inc is a dedicated identity and trusted onboarding policy like NIST SP 800-63-3, which directly addresses Mongrov's gateway failure by defining technical requirements in each of the areas of identity proofing, claimant authentication, and stronger remote credential assurance. These are aimed at authenticating the legitimacy, location, and employment credentials of remotely recruited IT staff.

Within this framework, the Identity Assurance Level (IAL) is used to determine whether an applicant has provided sufficient identity evidence during onboarding. This is important in Mongrov Inc's case because it seems to have lacked this form of structured verification, which allowed fraudulent workers to obtain organisational accounts without properly validated identity evidence. NIST also introduces the Authenticator Assurance Level (AAL), which is designed to ensure stronger future login security through controls such as MFA and phishing-resistant authenticators. This helps organisations reduce the risk of malicious users maintaining trusted access through weak credentials.

Alongside this, additional UK onboarding verification checks like the Disclosure and Barring Service (DBS) [5] should be used to provide supplementary assurance that successfully proofed applicants do not present undisclosed criminal, employment, or identity-related concerns. While such checks cannot independently guarantee cyber trustworthiness, they strengthen pre-employment due diligence by reducing sole reliance on document authenticity during remote recruitment. Collectively, these controls provide Mongrov Inc with the strongest preventative reduction in attack likelihood by attempting to block fraudulent legitimacy before internal trust is ever established.

However, this onboarding verification process is getting harder with the introduction of deepfake technologies, since attackers are actively using AI-generated audio, video, or personas to pose as someone else during remote interviews and landing offers [6]. This in turn creates huge operational and recruitment burdens, since it wastes the recruiters' time interviewing and onboarding individuals who misrepresent themselves, which doesn't only cause operational delays but also introduces significant compliance, security, and reputational risks when fraudulent hires gain access to systems or sensitive data [7]. Furthermore, this trend is only set to increase as deepfake tools become cheaper and more accessible, with current figures showing deepfake fraud attempts in hiring jumping roughly 1,300% from 2023 to 2024 [8].

3.2 Role-Based Access Control and Least Privilege Policy

Beyond covering the initial onboarding weaknesses, Mongrov Inc. should implement a structured Role-Based Access Control (RBAC) model to regulate the level of sensitive data and internal systems a remote worker is permitted to access. The firm can do this by utilising the principle of least privilege, which relates to the zero-trust security approach by ensuring each user has an appropriate level of access based on the tasks they need to perform, allowing them to access only the data necessary for their role [9]. This is particularly relevant in Mongrov Inc's case because fraudulent personnel appear to have converted successful employment onboarding directly into wider internal access without sufficient role-linked restriction. However, this adoption requires a significant investment of human resources, capital, and time, competing with other IT projects for limited resources, which explains why organisations cannot deploy it instantly, with most organisations taking around 18 months [10]. Additionally, this implementation is only valid until this access model is maintained, since business changes faster than access models [11], with 61.5% of businesses changing their business models at least once, and a further 98% of businesses believing their business models will have to change in the next three years [12].

3.3 Continuous Monitoring and Insider Detection Policy

Even with preventative onboarding and restrictive access governance, Mongrov Inc still requires a continuous monitoring and insider threat governance policy capable of identifying malicious behaviour occurring through authenticated employee accounts. This can be achieved through implementing periodic insider risk reviews, where users with privileged access are regularly monitored for suspicious activity, ensuring malicious individuals operating with legitimate system access are incapable of causing severe organisational harm despite existing preventative controls [13, 14]. Furthermore, suspicious internal escalation should be monitored through audit logging, since audit trails provide accountability and enable near real-time detection of suspicious behaviour before threats escalate [15]. This is particularly relevant in Mongrov Inc's case because the compromise appears to have persisted through apparently trusted employee accounts, meaning successful static account authentication alone would have provided insufficient verification for a stand-alone indicator of user legitimacy.

However, risk reviews require focus and strategy, yet many teams face challenges such as: data overload, false positives, and inconsistent auditing [16]. Moreover, this process cannot be fully automated through traditional insider-threat detection models, since rare malicious activity can cause over-fitting toward benign behaviour, while opaque

outputs make alerts difficult for auditors to interpret or act upon [17]. Despite these practical limitations, such challenges remain justified given that delayed behavioural detection significantly increases both compromise duration and the scale of resulting internal damage.

3.4 Incident Response and Account Containment Policy

In addition to insider monitoring, Mongrov Inc still requires a formal incident response and account containment policy like NIST SP 800-61 Rev.3, in order to prevent delayed organisational reaction from enabling further compromise. This is because it focuses on containing the incident, followed by coordinating response procedures to not only prevent post-detection cascading damage, but also align with other security and compliance frameworks, including CMMC and DFARS [18]. This is particularly relevant for Mongrov Inc, since malicious insiders operating under valid internal trust can continue causing damage after initial suspicion unless the organisation has a predefined process for rapid account isolation and coordinated containment. For instance, the firm could set up forensic logging retention to ensure a legal reporting chain is always available in case further suspicious activity gets detected.

However, maintaining this level of response readiness requires trained personnel (e.g., SOC analysts, GRC analysts, and threat responders), capable of carrying out these actions, which costs time, rehearsal, and staffing resources. This is becoming increasingly difficult in the age of AI, where threat actors have adopted AI more quickly than governments and private companies have adopted it for cyber defence [19]. Even with these challenges, such a policy remains necessary to ensure that detected insider misuse does not continue escalating during internal hesitation.

3.5 Practical Limitations of Policy Enforcement

Despite the security benefits provided by these controls, Mongrov Inc may still face difficulties implementing them across the organisation at the same time. This is because measures such as stricter identity verification, role-based restrictions, and behavioural monitoring will all require larger security expenditure, since firms will have to divert their spending from new, cutting-edge technologies to cyber security [20]. This may become particularly difficult due to the ongoing shortage of approximately 4.8 million qualified cyber security professionals [21]. In addition, achieving full organisational compliance depends on multiple factors, including the organisation’s size, current cyber security maturity, and available resources, with the average firm taking several months to over a year to achieve compliance, as shown in Figure 1.



Figure 1: Typical NIST 800-53 compliance implementation timeline

4 Recommendations

The policy framework proposed in Section 3 must therefore prioritise the implementation of layered controls capable of reducing both compromise likelihood and post-detection organisational impact.

4.1 Risk-Based Policy Prioritisation

The highest implementation priority should be Identity Verification and Trusted Onboarding (e.g., Microsoft Entra Verified ID), especially for highly skilled remote IT workers who are tasked with managing critical infrastructure, which is vital to the organisation. This is because it disrupts the compromise before internal access is granted, which provides the strongest reduction in attack likelihood [22].

Following onboarding assurance, Mongrov Inc should prioritise Role-Based Access Control (RBAC) and Least Privilege Enforcement. This is because organisations must still assume that some malicious actors may bypass initial verification procedures. For instance, for remote IT workers, only IT Admins should have the highest level of access, including permissions to change network configurations, manage security settings, and handle sensitive data, while lower level IT support roles should only be able to access technical resources needed for troubleshooting and support tasks. However, neither role should have access to alter employee salary details, which might be reserved for HR roles [23].

The third implementation priority should involve Continuous Monitoring on existing employees, since it allows businesses to assess their security posture, detect vulnerabilities, and maintain regulatory compliance across multiple frameworks such as PCI DSS [24].

The final implementation priority should focus on Incident Response and Account Containment Procedures intended to minimise escalation following compromise detection. This is because without effective containment, organisations can face extended dwell times, operational disruptions, and expensive recovery costs averaging \$4.88 million in 2024 [25], which in turn can also preserve stakeholder confidence [26].

Although prioritised individually, the proposed policies provide the greatest organisational protection when operating together as layered security mechanisms. This is because it supports Mongrov Inc in implementing a defence-in-depth approach, which helps to ensure that even if one line of defence is compromised, additional layers exist as a backup to ensure that threats are stopped along the way. Moreover, defence-in-depth addresses the security vulnerabilities inherent not only with hardware and software but also with people, as negligence or human error often contributes to organisational cyber breaches [27].

5 Conclusion

This report analyses how Mongrov Inc's systemic governance weakness in employee onboarding, access governance, and insider monitoring led to organisational compromise, and proposes a layered implementation and remediation strategy designed to reduce both the likelihood and impact of future insider threats, while improving accountability, containment readiness, and long-term organisational cyber resilience.

References

- [1] Simon Sharwood. *North Korea’s Fake IT Worker Scam Hauled in \$88M*. Published Fri 13 Dec 2024 00:32 UTC. The Register. Dec. 13, 2024. URL: <https://www.theregister.com/security/2024/12/13/north-koreas-fake-it-worker-scam-hauled-in-88m/1150166> (visited on 05/09/2026).
- [2] Nitesh Patel, James Duffy, and Lewis Flynn. *Rogue Employees Data Breach: UK Supermarket Chain Not Liable in Class Action*. Published May 2020. Gilchrist Connell. May 2020. URL: <https://www.gclegal.com.au/insights/rogue-employees-data-breach-uk-supermarket-chain-not-liable-in-class-action> (visited on 05/09/2026).
- [3] Felix Rosbach. *Rogue Staff Member at Leading Cybersecurity Company Leaks Customer Data*. Published under Data Protection, Compliance, and Data Breaches, 3 December 2019. Comforte AG. Dec. 3, 2019. URL: <https://insights.comforte.com/rogue-staff-member-at-leading-cybersecurity-company-leaks-customer-data> (visited on 05/09/2026).
- [4] Thom Bradley. *Missing on Continuous Monitoring Leads to Breaches*. Published 5 November 2020; 5 min read. NSC42 Ltd. Nov. 5, 2020. URL: <https://www.nsc42.co.uk/post/missing-on-continuous-monitoring-leads-to-breaches> (visited on 05/09/2026).
- [5] UK Government. *Identity Document Validation Technology in the Right to Work and Right to Rent Schemes and DBS Pre-employment Checking*. Guidance published on GOV.UK. HM Government. 2024. URL: <https://www.gov.uk/government/publications/digital-identity-document-validation-technology-idvt/identity-document-validation-technology-in-the-right-to-work-and-right-to-rent-schemes-and-dbs-pre-employment-checking-accessible-version> (visited on 04/28/2026).
- [6] Rightcheck. *Deepfake Candidates Are Here – How to Protect Your Hiring Process*. General Information, INSIGHTS, published 15 July 2025. Rightcheck. July 15, 2025. URL: <https://rightcheck.io/deepfake-candidates-are-here-how-to-protect-your-hiring-process/> (visited on 05/10/2026).
- [7] Tiffany Conaway. *How to Stop Hiring Fraud with Identity Verification*. Published 4 March 2026. Checkr. Mar. 4, 2026. URL: <https://checkr.com/resources/articles/stop-hiring-fraud-identity-verification> (visited on 05/10/2026).
- [8] Brian Thompson. *AI Job Scams 2026*. Published 29 April 2026. Defend-ID. Apr. 29, 2026. URL: <https://blog.defend-id.com/2026/04/29/ai-job-scams-2026/> (visited on 05/10/2026).
- [9] Cloudflare. *Principle of Least Privilege*. Cloudflare Learning Center. Cloudflare. 2026. URL: <https://www.cloudflare.com/en-gb/learning/access-management/principle-of-least-privilege/> (visited on 05/03/2026).
- [10] Alan C. O’Connor and Ross J. Loomis. *Economic Analysis of Role-Based Access Control*. Tech. rep. Final Report prepared for NIST Program Office, December 2010. National Institute of Standards and Technology, Dec. 2010. URL: https://csrc.nist.gov/files/pubs/other/2010/12/19/economic-analysis-of-rbac-final-report/final/docs/20101219_rbac2_final_report.pdf (visited on 05/03/2026).

- [11] Gene Moody. *RBAC Implementation: Best Practices*. Published December 23, 2025; updated December 19, 2025. Action1. Dec. 23, 2025. URL: <https://www.action1.com/blog/rbac-implementation-best-practices/> (visited on 05/03/2026).
- [12] Timothy Tim Hughes. *98% of Businesses Believe Their Business Models Will Have to Change in the Next Three Years*. LinkedIn article discussing AlixPartners Disruption Index findings. LinkedIn. Jan. 18, 2023. URL: <https://www.linkedin.com/pulse/98-businesses-believe-business-models-have-change-hughes-%E6%8F%90%E5%A7%86-%E4%BC%91%E6%96%AF/> (visited on 05/03/2026).
- [13] SANS Institute. *Continuous Monitoring Effectiveness Against Detecting Insider Threat*. SANS Cyber Research. SANS Institute. 2024. URL: <https://www.sans.edu/cyber-research/39975> (visited on 05/09/2026).
- [14] Findlay Whitelaw, Jackie Riley, and Nebrase Elmrabbit. “A Review of the Insider Threat, a Practitioner Perspective Within the U.K. Financial Services”. In: *IEEE Access* 12 (Mar. 4, 2024). Received 15 January 2024, accepted 27 February 2024, published 4 March 2024, pp. 34752–34768. URL: <https://ieeexplore.ieee.org/document/10458945> (visited on 05/03/2026).
- [15] National Cyber Security Centre. *Logging and Monitoring*. Part of the Securing HTTP-based APIs guidance collection. National Cyber Security Centre. Apr. 3, 2025. URL: <https://www.ncsc.gov.uk/collection/securing-http-based-apis/6-logging-and-monitoring> (visited on 05/03/2026).
- [16] Hoop.dev. *Audit Logs Threat Detection: A Guide to Strengthen Security*. Published August 25, 2022; 2 min read. Hoop.dev. Aug. 25, 2022. URL: <https://hoop.dev/blog/audit-logs-threat-detection-a-guide-to-strengthen-security> (visited on 05/03/2026).
- [17] Chengyu Song et al. “Audit-LLM: Multi-Agent Collaboration for Log-based Insider Threat Detection”. In: *arXiv preprint arXiv:2408.08902* (Aug. 12, 2024). arXiv:2408.08902v1 [cs.CR], published 12 August 2024. URL: <https://arxiv.org/abs/2408.08902> (visited on 05/03/2026).
- [18] Mark Larson. *NIST SP 800-61 Revision 3: Complete Guide to the New Incident Response Framework*. Published 13 August 2025; Author: Mark Larson (Partner — CISSP, CISA). Linford & Company LLP. Aug. 13, 2025. URL: <https://linfordco.com/blog/nist-sp-800-61/> (visited on 05/09/2026).
- [19] Derek B. Johnson. “Attackers are exploiting AI faster than defenders can keep up, new report warns”. In: *CyberScoop* (Mar. 2026). Accessed: 2026-05-03. URL: <https://cyberscoop.com/booz-allen-report-ai-helps-attackers-move-faster-than-current-defenses/>.
- [20] Natasha Nelson and Stuart Madnick. *Trade-offs between Digital Innovation and Cyber-Security*. Working Paper CISE# 2017-03. Working Paper CISE# 2017-03, March 2017. MIT Center for Information Systems Research, Mar. 2017. URL: <https://cams.mit.edu/wp-content/uploads/2017-03.pdf> (visited on 05/10/2026).
- [21] World Economic Forum. *Global Cybersecurity Outlook 2025*. Published 13 January 2025. World Economic Forum. Jan. 13, 2025. URL: <https://www.weforum.org/publications/global-cybersecurity-outlook-2025/> (visited on 05/10/2026).

- [22] Harvard University. *Resources for Onboarding and Employment Screening*. Fact sheet, as of July 2024. Harvard University. July 25, 2024. URL: https://ari.hms.harvard.edu/sites/default/files/assets/onboarding-and-employment-screening-fact-sheet_07-25-2024_508.pdf (visited on 05/09/2026).
- [23] WorkOS. *Role-Based Access Control Example*. Published 23 August 2024. WorkOS. Aug. 23, 2024. URL: <https://workos.com/blog/role-based-access-control-example> (visited on 05/09/2026).
- [24] Rajnish Kumar. *Why Continuous Monitoring Is the Future of Remote Work Security*. Published 21 February 2024 at 4:46 PM. RemoteDesk. Feb. 21, 2024. URL: <https://remotedesk.com/blog/why-continuous-monitoring-is-the-future-of-remote-work-security/> (visited on 05/09/2026).
- [25] Matt Garcia. *Incident Response Containment*. Date not provided. ReliaQuest. URL: <https://reliaquest.com/cyber-knowledge/incident-response-containment/> (visited on 05/09/2026).
- [26] Sygnia. *The Critical Importance of an Incident Response Plan*. Published 16 January 2025; 5 min read. Sygnia. Jan. 16, 2025. URL: <https://www.sygnia.co/blog/critical-importance-incident-response-plan/> (visited on 05/09/2026).
- [27] Fortinet. *What Is Defense in Depth? Defined and Explained*. Fortinet Cyber Glossary. Fortinet. 2026. URL: <https://www.fortinet.com/resources/cyberglossary/defense-in-depth> (visited on 05/10/2026).
- [28] Paul A. Grassi, Michael E. Garcia, and James L. Fenton. *Digital Identity Guidelines. NIST Special Publication 800-63-3*. NIST Special Publication 800-63-3. National Institute of Standards and Technology. 2020. URL: <https://pages.nist.gov/800-63-3/sp800-63-3.html> (visited on 04/28/2026).
- [29] Richard Boorman and Kathryn Hopkins. *Prisoners' Criminal Backgrounds and Proven Re-offending after Release. Results from the Surveying Prisoner Crime Reduction (SPCR) Survey*. Research Summary 8/12. Ministry of Justice Analytical Services Research Summary. Ministry of Justice, 2012. URL: <https://assets.publishing.service.gov.uk/media/5a7b86e840f0b66a2fc06bdb/prisoners-criminal-backgrounds-and-proven-re-offending-after-release.pdf> (visited on 05/02/2026).
- [30] Scottish Centre for Crime and Justice Research. *Study Finds Criminal Record Tick Box Failing Employers and Job Applicants*. Summary of findings from Beth Weaver's review on criminal record disclosure. Scottish Centre for Crime and Justice Research. Jan. 4, 2019. URL: https://www.sccjr.ac.uk/news_item/study-finds-criminal-record-tick-box-failing-employers-and-job-applicants/ (visited on 05/02/2026).
- [31] Samuel Gaston-Raoul. *Fake Employees, Real Threat: Decentralized Identity to Combat Deepfake Hiring?* Microsoft Security analysis of deepfake-assisted fraudulent remote hiring. Microsoft Security Community Blog. Jan. 6, 2026. URL: <https://techcommunity.microsoft.com/blog/microsoft-security-blog/fake-employees-real-threat-decentralized-identity-to-combat-deepfake-hiring/4479864> (visited on 05/02/2026).

- [32] Marlena Ciechan-Kujawa and Michał Buszko. “Complexity of Changes in the Business Model: An Empirical Research”. In: *Journal of Entrepreneurship, Management and Innovation* (Nov. 6, 2020). Submitted 01/08/2020, revised 30/09/2020 and 22/10/2020, accepted 06/11/2020. URL: `add_pdf_source_if_available` (visited on 05/03/2026).

Appendices

A AI Declaration and Academic Integrity

Limited AI-assisted tools were used during the development and documentation of this coursework, in accordance with the module's AI Collaboration policy, alongside the University's wider AI usage policy.

ChatGPT was also used to assist with LaTeX formatting tasks, primarily including:

- Initial report layout and contents page generation (Figure 2)
- Harvard reference formatting through a separate `reference.bib` file (Figure 3)

Grammarly was used for:

- Minor grammar correction to improve readability
- Final proofreading

Comet was used to help identify:

- Relevant academic sources
- Relevant industry and blog sources (Figure 4)

All final written analysis, policy recommendations, and evaluative conclusions were independently completed and critically assessed by the author.

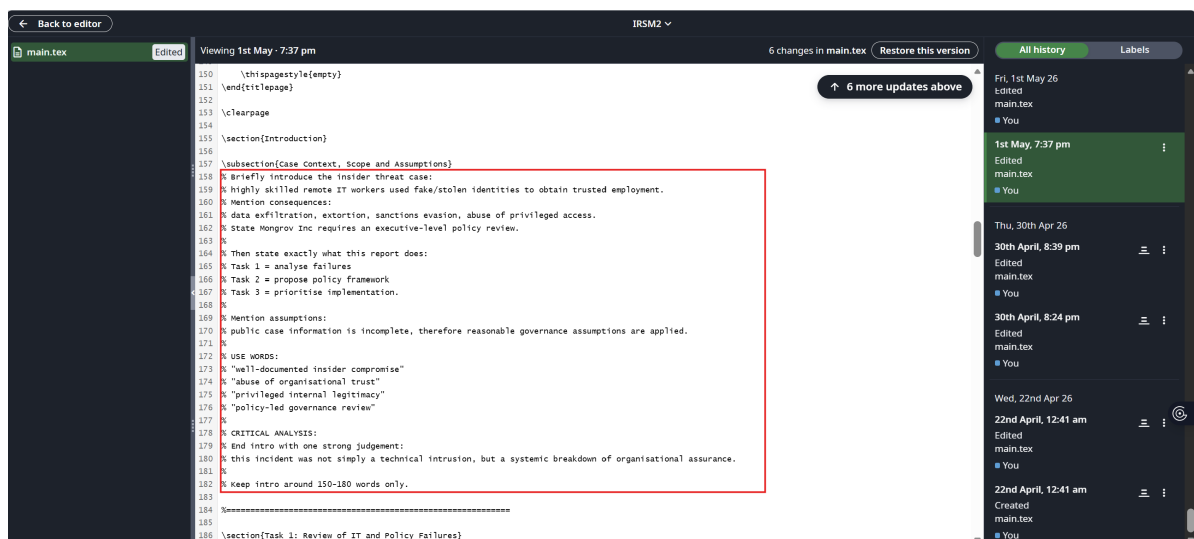


Figure 2: Example of AI-assisted report structuring and drafting guidance.

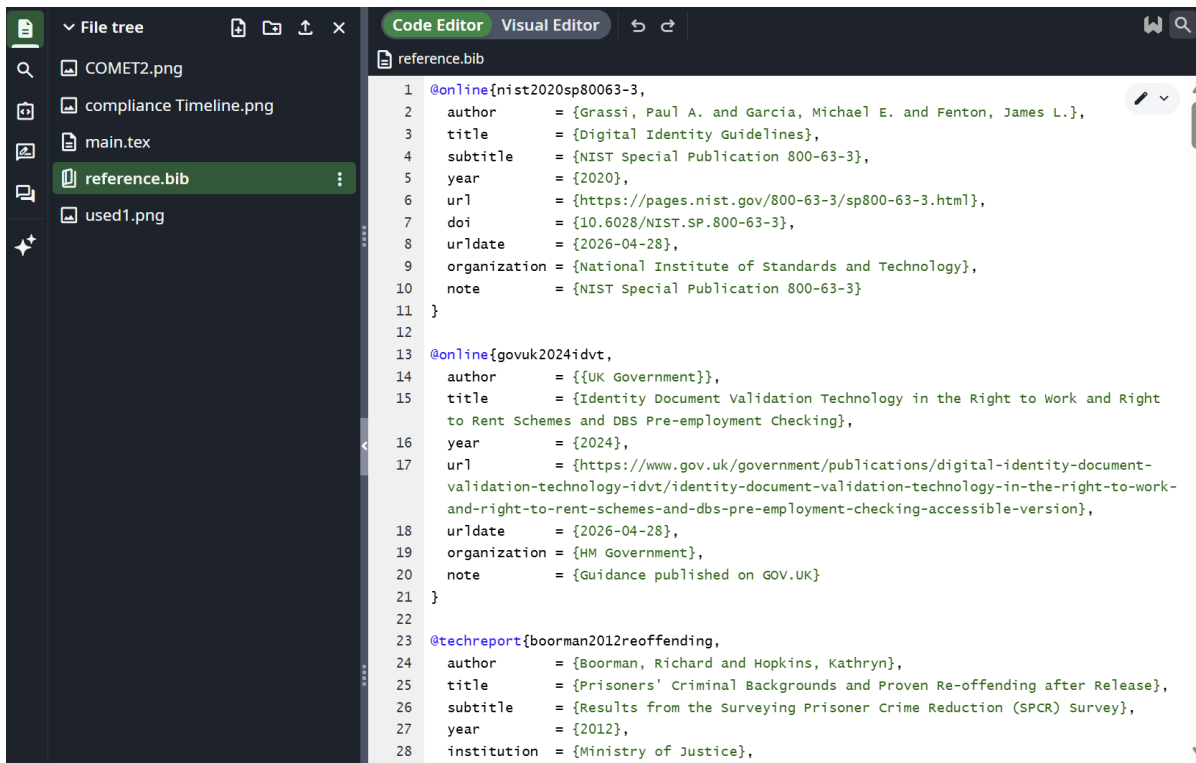


Figure 3: Use of a separate BibTeX file for Harvard reference management.

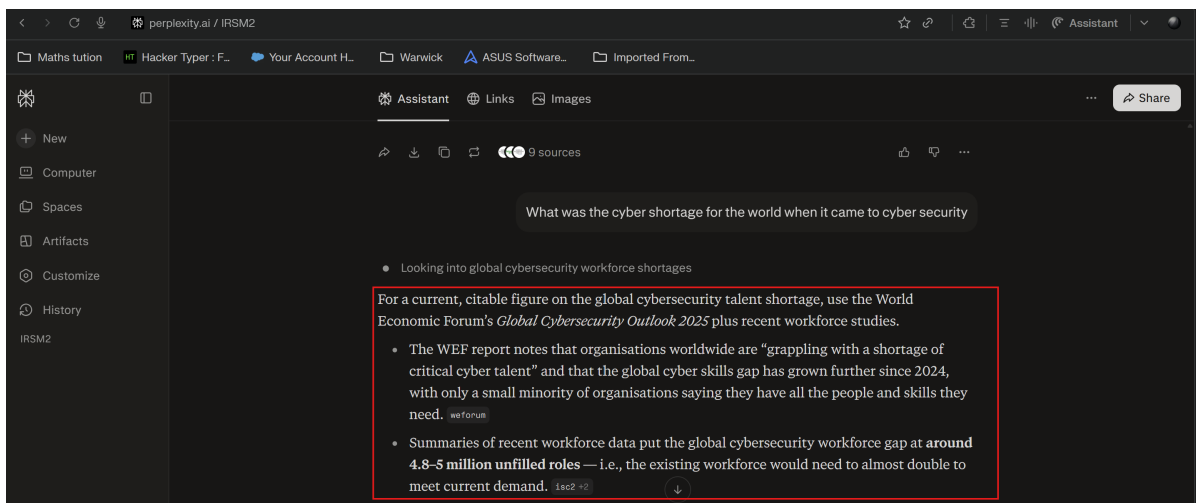


Figure 4: Example of AI-assisted source discovery and research support.